

Operationalizing CVSS v4.0 Environmental Metrics with AI-Assisted Evidence Collection and Traceability

Anonymous Author(s)

Affiliation withheld for double-blind review

Abstract—CVSS v4.0 defines Environmental metrics that adapt vulnerability assessment to a consumer organization’s deployment context. This paper presents an AI/watcher-assisted workflow for collecting, structuring, and tracing evidence used to support Environmental metric assessment. The workflow preserves official CVSS semantics and treats its outputs as evidence-backed candidate recommendations requiring human review. The evaluation uses 30 scenarios, including 12 NVD records carrying CVSS v4.0 data and 18 curated synthetic scenarios. Generated artifacts achieved 100.00 percent evidence coverage and 100.00 percent trace completeness. Operational priority changed in 22 of 30 scenarios. These results demonstrate workflow execution and traceability, not predictive superiority or production effectiveness.

Index Terms—CVSS v4.0, Environmental metrics, vulnerability prioritization, artificial intelligence, traceability, reproducibility, human review

I. INTRODUCTION

The Common Vulnerability Scoring System is widely used to communicate vulnerability severity. Operational remediation decisions, however, frequently require more than a Base score because asset criticality, deployment context, exposure, and compensating controls can change remediation urgency.

CVSS v4.0 distinguishes Base, Threat, Environmental, and Supplemental metric groups [1], [2]. Environmental metrics allow consumer organizations to represent local context [3], [4]. Selecting these values consistently requires evidence, uncertainty handling, and reviewable decision records.

This paper presents an AI/watcher-assisted workflow that structures evidence, suggests candidate Environmental values, flags uncertainty, requires human review, and exports reproducible trace artifacts. The contribution is a method and prototype workflow, not a new scoring standard.

II. BACKGROUND

The workflow preserves CVSS-B, CVSS-BT, CVSS-BE, and CVSS-BTE labeling. Base information remains separate from consumer-side Environmental assessment. Threat information is treated as time-sensitive evidence requiring independent review. Supplemental information remains contextual.

Environmental assessment includes Security Requirements and Modified Base metrics. Their selection depends on asset importance, architecture, exposure, privileges, and compensating controls. The proposed workflow assists evidence organization and analyst review rather than autonomous scoring.

III. PROBLEM STATEMENT

Environmental assessment can be difficult because relevant evidence is often incomplete or distributed across multiple systems. This can reduce reproducibility, create inconsistent assessments across similar assets, and cause remediation decisions to over-rely on Base severity.

IV. PROPOSED WORKFLOW

The workflow performs eight activities:

- 1) ingest vulnerability and Base CVSS information;
- 2) collect consumer-side environmental evidence;
- 3) structure evidence into scenario fields;
- 4) suggest candidate Environmental metric values;
- 5) attach evidence and rationale;
- 6) flag uncertainty and missing evidence;
- 7) require explicit human review; and
- 8) export CSV, JSON, report, and table artifacts.

The workflow does not modify the CVSS v4.0 formula. Its outputs are human-reviewable candidate recommendations, not autonomous official scores.

V. PROTOTYPE ARCHITECTURE

The prototype contains a scenario dataset, validators, per-scenario trace JSON, generated tables, and manuscript artifacts. Each scenario stores Base information separately from curated Environmental context, candidate metric values, evidence, uncertainty flags, review status, and operational priority.

VI. EVALUATION DESIGN

The evaluation uses 30 scenarios. 12 scenarios use NVD vulnerability records carrying CVSS v4.0 information [5], [6], [7], [8], [9], [10], [11], [12], [13], [14], [15], [16]. The remaining 18 scenarios are explicitly marked as curated synthetic cases.

The Environmental contexts attached to the records are curated for workflow evaluation. A real CVE record does not imply that its local deployment context was obtained from NVD.

The evaluation measures workflow properties rather than predictive superiority: evidence coverage, trace completeness, uncertainty coverage, review status, and operational priority transitions.

TABLE I
DATASET AND WORKFLOW SUMMARY

Measure	Value
Scenarios	30
NVD/CVSS v4.0 records	12
Curated synthetic scenarios	18
Evidence coverage	100.00%
Trace completeness	100.00%
Rows requiring review	30
Priority shifts	22 (73.33%)

TABLE II
OPERATIONAL PRIORITY TRANSITIONS

Base priority	Environmental-aware priority	Count
critical	critical	3
high	critical	4
high	defer	1
high	high	2
high	medium	2
low	defer	2
low	high	1
low	low	1
low	medium	1
medium	critical	2
medium	defer	1
medium	high	6
medium	low	2
medium	medium	2

VII. RESULTS

All 30 scenarios contain evidence summaries and trace artifacts. Every scenario requires human review. Uncertainty flags are present in 100.00 percent of records.

Operational priority changed in 22 of 30 scenarios (73.33 percent). The average category delta was 0.2, with a maximum upward delta of 2.0 and a maximum downward delta of -3.0.

The priority delta is an operational category transition. It is not an official CVSS Environmental score difference and must not be interpreted as a modification of the CVSS formula.

VIII. DISCUSSION

The results support the feasibility of structuring Environmental assessment around evidence, uncertainty, traceability, and reviewability. The hybrid dataset includes NVD records carrying CVSS v4.0 information [17], but the attached consumer contexts remain curated.

The results demonstrate artifact completeness and workflow execution. They do not establish production effectiveness, scoring correctness, or predictive superiority.

TABLE III
CVSS-B SEVERITY DISTRIBUTION

Severity	Count
CRITICAL	3
HIGH	9
LOW	5
MEDIUM	13

IX. LIMITATIONS AND THREATS TO VALIDITY

The dataset is curated and partially synthetic. The consumer Environmental contexts do not represent measured production deployments.

The evaluation does not measure exploit likelihood, remediation outcomes, analyst time savings, or predictive superiority. Independent expert adjudication has not yet been completed. The NVD sample is time-bounded and must not be interpreted as representative of all CVSS v4.0 records.

X. CONCLUSION

This paper presents an AI/watcher-assisted workflow for supporting CVSS v4.0 Environmental metric assessment through evidence collection, traceability, uncertainty flags, and explicit human review. The method preserves official CVSS semantics and does not modify the standard.

Future work should add expert adjudication, peer-reviewed comparative baselines, inter-rater agreement analysis, and production-like evaluation.

REFERENCES

- [1] FIRST, "Common Vulnerability Scoring System Version 4.0," <https://www.first.org/cvss/v4.0/>, accessed: 2026-07-13.
- [2] —, "CVSS v4.0 Specification Document," <https://www.first.org/cvss/v4.0/specification-document>, accessed: 2026-07-13.
- [3] —, "CVSS v4.0 User Guide," <https://www.first.org/cvss/v4.0/user-guide>, accessed: 2026-07-13.
- [4] —, "CVSS v4.0 Implementation Guide," <https://www.first.org/cvss/v4.0/implementation-guide>, accessed: 2026-07-13.
- [5] National Vulnerability Database, "CVE-2026-4251 Detail," <https://nvd.nist.gov/vuln/detail/CVE-2026-4251>, 2026, accessed: 2026-07-13.
- [6] —, "CVE-2026-4252 Detail," <https://nvd.nist.gov/vuln/detail/CVE-2026-4252>, 2026, accessed: 2026-07-13.
- [7] —, "CVE-2026-4270 Detail," <https://nvd.nist.gov/vuln/detail/CVE-2026-4270>, 2026, accessed: 2026-07-13.
- [8] —, "CVE-2026-28490 Detail," <https://nvd.nist.gov/vuln/detail/CVE-2026-28490>, 2026, accessed: 2026-07-13.
- [9] —, "CVE-2026-28498 Detail," <https://nvd.nist.gov/vuln/detail/CVE-2026-28498>, 2026, accessed: 2026-07-13.
- [10] —, "CVE-2026-29510 Detail," <https://nvd.nist.gov/vuln/detail/CVE-2026-29510>, 2026, accessed: 2026-07-13.
- [11] —, "CVE-2026-29513 Detail," <https://nvd.nist.gov/vuln/detail/CVE-2026-29513>, 2026, accessed: 2026-07-13.
- [12] —, "CVE-2026-29520 Detail," <https://nvd.nist.gov/vuln/detail/CVE-2026-29520>, 2026, accessed: 2026-07-13.
- [13] —, "CVE-2026-29521 Detail," <https://nvd.nist.gov/vuln/detail/CVE-2026-29521>, 2026, accessed: 2026-07-13.
- [14] —, "CVE-2026-3644 Detail," <https://nvd.nist.gov/vuln/detail/CVE-2026-3644>, 2026, accessed: 2026-07-13.
- [15] —, "CVE-2026-4224 Detail," <https://nvd.nist.gov/vuln/detail/CVE-2026-4224>, 2026, accessed: 2026-07-13.
- [16] —, "CVE-2026-4253 Detail," <https://nvd.nist.gov/vuln/detail/CVE-2026-4253>, 2026, accessed: 2026-07-13.

- [17] National Institute of Standards and Technology, “National Vulnerability Database API,” <https://nvd.nist.gov/developers/vulnerabilities>, accessed: 2026-07-13.